

Registre des risques (Risk Register)

1. Objectif

Identifier, analyser, prioriser et suivre les risques susceptibles d'affecter la sécurité, la conformité, la disponibilité et la réussite globale de la plateforme de gestion numérique des auto-écoles et examens.

2. Méthodologie

- Identification des risques
- Évaluation de la probabilité
- Évaluation de l'impact
- Définition des mesures de traitement
- Suivi et réévaluation périodique

Références : ISO 31000, ISO/IEC 27005, NIST Risk Management Framework.

3. Échelle d'évaluation

Probabilité

- Faible (1)
- Moyenne (2)
- Élevée (3)

Impact

- Faible (1)
- Moyen (2)
- Élevé (3)

4. Registre des risques principaux

ID	Catégorie	Description du risque	Probabilité	Impact	Niveau	Mesures de traitement
R1	Sécurité	Cyberattaque (ransomware, intrusion)	Élevée (3)	Élevé (3)	Critique	MFA, SIEM, PRA, tests sécurité
R2	Données	Fuite de données personnelles	Moyenne (2)	Élevé (3)	Élevé	Chiffrement, IAM, journalisation
R3	Réglementaire	Non-conformité à la loi sur les données	Faible (1)	Élevé (3)	Élevé	AIPD, gouvernance données, audits

ID	Catégorie	Description du risque	Probabilité	Impact	Niveau	Mesures de traitement
R4	Disponibilité	Indisponibilité prolongée du système	Moyenne (2)	Élevé (3)	Élevé	PCA/PRA, redondance
R5	Tiers	Défaillance d'un fournisseur critique	Moyenne (2)	Moyen (2)	Moyen	Politique tiers, contrats, PRA
R6	Opérationnel	Erreurs humaines (mauvaise manipulation)	Élevée (3)	Moyen (2)	Élevé	Formation, contrôles, journalisation
R7	Réputation	Perte de confiance publique	Faible (1)	Élevé (3)	Élevé	Communication de crise, transparence
R8	IA	Biais ou erreurs des systèmes IA	Moyenne (2)	Moyen (2)	Moyen	Validation données, supervision humaine
R9	Juridique	Litiges liés aux résultats d'examen	Faible (1)	Moyen (2)	Moyen	Traçabilité, audit, procédures
R10	Physique	Sinistre sur site (incendie, inondation)	Faible (1)	Élevé (3)	Élevé	PRA, hébergement redondant

5. Propriétaires de risques

Chaque risque doit être attribué à un responsable (IT, Sécurité, Juridique, Direction, Métier).

6. Plan de traitement

- Réduction
- Transfert (assurance, sous-traitance)
- Acceptation
- Évitement

7. Suivi et reporting

- Revue trimestrielle
- Mise à jour du registre
- Reporting à la direction

8. Conformité et références

- ISO 31000 (Risk Management)
- ISO/IEC 27005
- NIST Risk Management Framework

9. Mise à jour

- Revue trimestrielle
- Mise à jour après incident majeur ou changement stratégique

Document de référence interne – Registre des risques pour la plateforme de gestion numérique des auto-écoles et examens.